

SmartStock Pro

Dokumen Analisis Risiko Keamanan

Dokumentasi Mini Project BNSP Web Developer

2026

DOKUMEN ANALISIS RISIKO KEAMANAN

SMARTSTOCK PRO

1. Pendahuluan

Dokumen ini menjelaskan analisis risiko keamanan informasi untuk SmartStock Pro, yaitu Website Sistem Manajemen Inventaris Multi Gudang berbasis React.js, Laravel REST API, PostgreSQL, dan Laravel Sanctum. Sistem ini digunakan oleh akun internal perusahaan dengan role admin, warehouse_manager, staff, dan viewer.

SmartStock Pro pada tahap ini merupakan MVP/demo implementasi untuk studi kasus BNSP. Fitur inti seperti login, role access, Role Access UI Management, CRUD data master, transaksi stok, stok per gudang, transfer stok antar gudang, audit log, upload gambar produk, import CSV via queue, background report generation, export laporan, dan health check telah tersedia. Beberapa fitur lanjutan seperti notifikasi email, WebSocket real-time, Import Excel, FIFO/LIFO batch layer penuh, backend PDF generator, monitoring CPU/disk/network asli, dan queue production-ready masuk dalam rencana pengembangan lanjutan.

Tujuan dokumen ini adalah mengidentifikasi aset informasi, risiko utama, dampak, kontrol keamanan yang sudah diterapkan, serta langkah mitigasi yang disarankan agar sistem lebih aman saat dikembangkan menuju lingkungan produksi.

2. Identifikasi Aset Informasi

Aset Informasi	Deskripsi	Tingkat Kepentingan
Akun pengguna	Data user internal, email, nama, role, dan password hash	Tinggi
Token autentikasi	Bearer token Laravel Sanctum untuk akses API	Tinggi
Data produk	SKU, nama produk, kategori, supplier, stok saat ini, stok minimum, gambar produk	Tinggi

Data gudang	Informasi lokasi dan identitas gudang perusahaan	Tinggi
Data supplier	Kontak supplier, email, telepon, dan alamat	Sedang
Transaksi stok	Riwayat stok masuk dan stok keluar	Tinggi
Transfer stok antar gudang	Riwayat perpindahan stok dari gudang asal ke gudang tujuan	Tinggi
Stok per gudang	Kuantitas produk pada setiap gudang	Tinggi
Audit log	Catatan aktivitas pengguna, waktu, modul, aksi, dan IP address	Tinggi
Error log	Catatan error aplikasi dengan severity, source, message, user, dan IP address	Sedang
File gambar produk	File upload produk dalam format jpg/jpeg/png	Sedang
Laporan CSV/PDF	Data transaksi stok yang diekspor untuk kebutuhan bisnis	Tinggi
Konfigurasi aplikasi	.env, kredensial database, app key, dan pengaturan environment	Tinggi

3. Risiko Keamanan

Risiko	Deskripsi	Dampak
SQL Injection	Penyerang mencoba memasukkan query berbahaya melalui input API	Kebocoran, perubahan, atau penghapusan data
Cross-Site Scripting (XSS)	Input berbahaya ditampilkan di frontend sebagai script	Pencurian token, perubahan tampilan, atau eksekusi aksi tidak sah

CSRF/API token misuse	Token digunakan oleh pihak tidak sah atau disalahgunakan	Akses API tanpa izin
Password lemah	Password mudah ditebak atau digunakan ulang	Akun internal dapat diambil alih
Unauthorized access	User mengakses fitur yang tidak sesuai role	Perubahan data inventaris oleh pihak tidak berwenang
Session idle terlalu lama	Token tetap aktif walau user meninggalkan perangkat	Penyalahgunaan sesi aktif
Upload file berbahaya	File bukan gambar atau terlalu besar diunggah ke sistem	Konsumsi storage, potensi penyalahgunaan file
Data leakage	Data inventaris atau laporan diakses oleh role tidak sesuai	Kebocoran informasi perusahaan
Error log exposure	Error log memuat informasi sensitif lalu dilihat oleh role tidak tepat	Kebocoran detail teknis sistem
Backup tidak tersedia	Database atau file hilang tanpa cadangan	Kehilangan data operasional
Audit log tidak lengkap	Aktivitas penting tidak tercatat	Sulit melakukan investigasi insiden
Race condition stok	Dua proses stok berjalan bersamaan tanpa kontrol transaksi	Stok gudang tidak konsisten

4. Dampak Risiko

Dampak risiko keamanan terhadap SmartStock Pro dapat dibagi menjadi beberapa kategori:

- Dampak kerahasiaan: data produk, supplier, transaksi stok, dan laporan dapat bocor kepada pihak yang tidak berhak.

- Dampak integritas: stok produk dapat berubah tidak sesuai transaksi sebenarnya.
- Dampak ketersediaan: sistem tidak dapat digunakan jika database, API, atau storage terganggu.
- Dampak akuntabilitas: tanpa audit log yang lengkap, perusahaan sulit mengetahui siapa yang melakukan perubahan data.
- Dampak operasional: kesalahan stok dapat mengganggu proses gudang, pembelian, dan laporan manajemen.

5. Mitigasi Risiko

Risiko	Mitigasi
SQL Injection	Menggunakan Eloquent ORM, Query Builder, validasi request, dan tidak menyusun raw query dari input user.
XSS	React melakukan escaping output secara default. Input tetap perlu divalidasi dan tidak boleh menampilkan HTML mentah tanpa sanitasi.
CSRF/API token misuse	API menggunakan Bearer Token Laravel Sanctum. Token disimpan di localStorage untuk MVP, dan perlu dievaluasi lebih lanjut untuk production.
Password lemah	Seeder menggunakan password minimal 8 karakter dan password disimpan dengan hashing Laravel. Jika fitur create/update user internal dibuat, wajib validasi huruf dan angka.
Unauthorized access	Middleware role membatasi akses API berdasarkan role. Frontend juga menyembunyikan menu/action sesuai role.
Session idle terlalu lama	Frontend menerapkan session timeout otomatis: modal muncul setelah idle 30 menit dan logout otomatis setelah 1 menit tanpa respons.

Upload file berbahaya	Validasi upload membatasi format jpg/jpeg/png dan ukuran maksimum 2 MB. Kegagalan validasi dicatat sebagai warning error log.
Data leakage	Endpoint sensitif seperti audit log dan error log hanya untuk admin dan warehouse_manager.
Error log exposure	Error log ditampilkan terbatas untuk role yang berwenang, dan sebaiknya tidak menyimpan password/token di field context.
Backup tidak tersedia	Disarankan backup database harian dan backup file gambar produk secara berkala.
Audit log tidak lengkap	Aksi utama seperti login, logout, CRUD master data, transaksi stok, dan export report dicatat ke audit log.
Race condition stok	Transfer stok antar gudang diproses menggunakan database transaction dan lock stok gudang.

6. Kontrol Keamanan yang Sudah Diterapkan

Kontrol keamanan yang sudah tersedia pada MVP SmartStock Pro:

- Autentikasi menggunakan Laravel Sanctum dengan Bearer Token.
- Password hashing menggunakan mekanisme Laravel.
- Public register dinonaktifkan; akun internal dibuat melalui seeder.
- Role-based access control melalui middleware role.
- Frontend role-based menu/action visibility.
- Proteksi endpoint API dengan middleware auth:sanctum.
- Validasi request pada controller backend.
- Audit log untuk aksi utama pengguna.
- Error log dengan severity info, warning, dan critical.
- Role Access UI Management untuk admin.
- Stok per gudang.
- Transfer stok antar gudang menggunakan database transaction.

- Import CSV produk menggunakan Laravel Queue database.
- Background report generation CSV menggunakan queue.
- Session timeout frontend untuk user idle.
- Validasi upload gambar produk untuk format dan ukuran.
- Health check API dan database, termasuk response time, memory usage, memory peak usage, PHP version, dan server time.
- Data master bersifat company-wide/global, tetapi tetap dilindungi oleh role access.

7. Risiko Tersisa

Beberapa risiko yang masih tersisa pada tahap MVP:

- Token masih disimpan di localStorage; pada production perlu evaluasi penggunaan cookie HttpOnly atau strategi token lifecycle yang lebih ketat.
- Monitoring server masih terbatas pada health check API/database, response time, memory usage, memory peak usage, PHP version, dan server time; belum mencakup CPU, disk IOPS, disk usage, dan network server asli.
- Notifikasi stok kritis masih berbasis fetch endpoint, belum real-time melalui WebSocket atau push notification.
- Error log harus dipastikan tidak menyimpan data sensitif seperti password, token, atau kredensial database.
- Backup dan restore belum diotomatisasi oleh aplikasi.
- Rate limiting login dan proteksi brute force perlu diperiksa kembali sebelum production.
- FIFO/LIFO batch layer penuh belum tersedia.
- Queue sudah functional untuk import CSV dan background report, tetapi production setup masih perlu service manager, retry policy, queue monitoring, dan worker deployment yang stabil.

8. Rencana Pengembangan Keamanan

Rencana pengembangan keamanan lanjutan:

1. Menambahkan rate limiting untuk login dan endpoint sensitif.
2. Menerapkan kebijakan password internal yang lebih kuat untuk user management.
3. Menggunakan cookie HttpOnly atau refresh token strategy untuk production.
4. Menambahkan monitoring server yang mencatat CPU, memory, disk usage, dan response time historis.
5. Menambahkan alert otomatis untuk error severity critical.
6. Menambahkan backup database terjadwal dan dokumentasi restore berkala.
7. Menambahkan sanitasi tambahan jika suatu saat aplikasi menampilkan rich text atau HTML.
8. Menambahkan audit trail yang lebih rinci untuk perubahan field penting.
9. Menambahkan review berkala terhadap role dan hak akses pengguna.
10. Menambahkan keamanan storage file, termasuk scanning file dan pemisahan object storage jika volume gambar meningkat.
11. Menambahkan backend PDF generator jika kebutuhan laporan formal tidak cukup dipenuhi oleh browser print.
12. Menambahkan Import Excel jika kebutuhan operasional membutuhkan format .xlsx/.xls.

9. Kesimpulan

SmartStock Pro MVP telah menerapkan kontrol keamanan dasar yang relevan untuk studi kasus BNSP, termasuk autentikasi Sanctum, password hashing, middleware role, Role Access UI Management, audit log, error log, validasi upload file, session timeout, stok per gudang, transfer stok antar gudang, import CSV via queue, background report generation, dan health check. Sistem sudah cukup untuk demo fitur inti inventaris multi-role dan multi-gudang.

Untuk penggunaan production, sistem masih membutuhkan penguatan pada manajemen token, backup otomatis, monitoring server lanjutan, notifikasi real-time, email notification, rate limiting, queue worker production setup, dan kontrol operasional lainnya. Fitur lanjutan seperti Import Excel, FIFO/LIFO batch layer penuh, backend PDF

generator, dan monitoring CPU/disk/network asli perlu direncanakan sebagai pengembangan berikutnya.